Cybersécurité — Bloc 3

BTS SIO 1re année

Découvrir le bloc, nommer les bons principes

Introduction à la cybersécurité (DICP)

Objectifs

- Situer le Bloc 3 : contexte métier, degré d'autonomie, les 4 compétences communes.
- Distinguer sécurité et sûreté, et nommer avec justesse les 4 principes DICP.
- Face à un incident concret, identifier le pilier D, I ou C menacé et proposer une réaction immédiate. (La Preuve est traitée dans une séquence ultérieure.)

Prérequis

- Aucun prérequis technique.

Sommaire

Partie	Contenu
Partie 1	Pourquoi un bloc à part ?
Partie 2	Sécurité ≠ sûreté, principes DICP
Partie 3	Activité : D, I ou C ?

Partie 1 — Pourquoi un bloc à part ?

Le cadre légal, avant tout le reste

Tout ce qui se pratique en cybersécurité — attaque comme défense — s'exerce à l'intérieur d'un cadre pénal strict. Le Code pénal, articles **323-1 et suivants** (chapitre « Des atteintes aux systèmes de traitement automatisé de données », issu de la loi Godfrain de 1988, régulièrement renforcé depuis — dernière révision majeure : la LOPMI, loi n°2023-22 du 24 janvier 2023), définit ce qui est interdit. Texte intégral de l'article central du chapitre, à titre d'exemple de ce à quoi ressemble un article de loi :

> « Le fait d'accéder ou de se maintenir, frauduleusement, dans tout ou partie d'un système de traitement automatisé de données est puni de trois ans d'emprisonnement et de 100 000 € d'amende.
>
> Lorsqu'il en est résulté soit la suppression ou la modification de données contenues dans le système, soit une altération du fonctionnement de ce système, la peine est de cinq ans d'emprisonnement et de 150 000 € d'amende.
>
> Lorsque les infractions prévues aux deux premiers alinéas ont été commises à l'encontre d'un système de traitement automatisé de données à caractère personnel mis en œuvre par l'État, la peine est portée à sept ans d'emprisonnement et à 300 000 € d'amende. »
>
> — Article 323-1 du Code pénal, version en vigueur depuis le 26 janvier 2023.

Le reste du chapitre, dans ses grandes lignes :

Article	Ce qu'il punit	Peine
323-2	Entraver ou fausser le fonctionnement d'un système (ex. déni de service)	5 ans, 150 000 € (7 ans, 300 000 € si système d'État)
323-3	Introduire, extraire, détenir, transmettre, supprimer ou modifier frauduleusement des données	5 ans, 150 000 € (7 ans, 300 000 € si système d'État)
323-3-1	Fournir un outil conçu pour commettre ces infractions	Peines de l'infraction visée — **sauf motif légitime, notamment de recherche ou de sécurité informatique**
323-3-2	(Depuis 2025) Plateforme en ligne facilitant sciemment des opérations manifestement illicites	7 ans, 500 000 € (10 ans, 1 000 000 € en bande organisée)
323-4	Participer à un groupement formé pour préparer ces infractions	Peines de l'infraction visée
323-4-1	Circonstance aggravante : bande organisée	10 ans, 300 000 €
323-4-2	Circonstance aggravante : mise en danger d'autrui ou obstacle aux secours	10 ans, 300 000 €
323-5	Peines complémentaires (personnes physiques)	Interdiction de droits, d'exercer, confiscation, fermeture d'établissement, exclusion des marchés publics…
323-6	Responsabilité pénale des personnes morales (entreprises)	Amende + peines de l'art. 131-39
323-7	Tentative des délits prévus par 323-1 à 323-3-1	Mêmes peines que l'infraction accomplie
323-8	Exception : services de renseignement de l'État agissant hors du territoire national	Chapitre non applicable

Attention

Ce cadre ne se discute jamais : c'est la limite absolue de tout ce qui sera appris dans ce bloc, y compris pour un test ou un exercice « juste pour voir ». L'exception de l'article 323-3-1 (motif légitime de recherche ou de sécurité informatique) est précieuse pour un futur professionnel SISR ou SLAM — mais elle ne dispense jamais d'une autorisation explicite avant d'intervenir sur un système qui n'est pas le vôtre.

Repère

Texte vérifié sur Légifrance (consultation directe, article par article).

La cybersécurité aujourd'hui

Quelques traits qui caractérisent le paysage actuel, et qui justifient l'existence de ce bloc de compétences :

- une **surface d'attaque en expansion constante** : cloud, mobile, objets connectés multiplient les points d'entrée possibles ;
- des **rançongiciels en hausse continue**, y compris contre des cibles autrefois peu visées (hôpitaux, collectivités, établissements scolaires) ;
- des **attaques de plus en plus automatisées**, parfois assistées par l'IA, tant côté attaque que côté défense ;
- un **cadre réglementaire qui se durcit** (RGPD, directive européenne NIS2) ;

- une **pénurie de compétences** reconnue dans le secteur — un vrai débouché professionnel pour les diplômés SISR comme SLAM.

Le vocabulaire de ces deux années

Les mots suivants seront rencontrés et définis au fil du Bloc 3, sur les deux années de BTS. Ils ne sont pas définis ici : les nommer une première fois suffit à préparer leur rencontre.

Menaces et risques	Protection technique	Preuve et gouvernance	Vers la spécialisation
Menace	Chiffrement	Preuve	Pare-feu *(SISR)*
Vulnérabilité	Authentification	Signature électronique	Test d'intrusion *(SISR)*
Analyse de risque	Identification	Non-répudiation	Durcissement *(SISR)*
Ingénierie sociale	Certificat	Journalisation	Vulnérabilité applicative, OWASP *(SLAM)*
Fuite de données	Hachage	Politique de sécurité	

Le Bloc 3 forme à la cybersécurité des services informatiques. D'après le référentiel, la personne titulaire du diplôme « exerce des activités pour répondre aux besoins de sécurité des services informatiques d'une organisation cliente notamment au regard du développement des menaces et attaques en provenance du cybermonde ».

Elle peut travailler pour l'entité informatique interne d'une organisation, une entreprise de services du numérique, une société de conseil ou un éditeur de logiciels.

> **Repère**
>
> Le Bloc 3 comprend 4 compétences communes aux deux options (SISR et SLAM), puis une 5e compétence spécifique à chaque option, travaillée à partir du semestre 2.

Les 4 compétences communes :

1. Protéger les données à caractère personnel
2. Préserver l'identité numérique de l'organisation
3. Sécuriser les équipements et les usages des utilisateurs
4. Garantir la disponibilité, l'intégrité et la confidentialité des services et des données de l'organisation face à des cyberattaques

Partie 2 — Sécurité ≠ sûreté, principes DICP

Construire la grille en classe entière

Sur feuille, d'abord seul puis en mise en commun. Répondez aux situations avant de consulter la synthèse ci-dessous. L'IA et la recherche Internet ne sont pas utilisées.

Situation d'entrée. L'application du lycée s'ouvre normalement, mais des notes ont été modifiées sans autorisation. Écrivez deux phrases : peut-on accéder au service ? Peut-on faire confiance aux données ?

Quatre besoins à faire émerger. Pour chaque cas, indiquez le besoin à garantir et les mots du récit qui justifient votre réponse.

- A : l'ENT est inaccessible au moment de déposer un devoir.
- B : un montant de facture a été modifié sans autorisation.
- C : une personne non autorisée lit un dossier médical.
- D : deux personnes se contredisent sur une modification : qui l'a faite, quand ?

Construisez ensuite au tableau et sur votre feuille une grille **principe / question à poser / exemple**, avec une ligne pour D, I, C et P. Pour D, demandez-vous notamment ce qui permettrait d'établir les faits : de quelles traces aurait-on besoin, et pourrait-on leur faire confiance ? Ici « cas D » désigne la quatrième situation, pas la disponibilité.

Comparer les frontières. À l'oral, expliquez l'effet commun d'une panne électrique et d'une attaque bloquant le même service, puis leur différence de cause. Sur feuille, justifiez le principe atteint dans ces deux autres cas :

un fichier copié sans autorisation dont l'original reste intact et accessible ; une application qui fonctionne mais affiche des stocks falsifiés.

Vérification individuelle, sans la synthèse. Inventez un incident en deux phrases : une situation concrète, puis le principe atteint avec sa justification. Quelques propositions sont discutées collectivement. La correction des situations est regroupée après les exercices.

Sécurité, sûreté : deux mots, deux périmètres

La **sûreté** concerne la continuité et la résilience d'un service face aux pannes et aux aléas (déjà abordée en Bloc 1 et Bloc 2 : sauvegarde, plan de continuité). La **sécurité** concerne la protection face à la **malveillance** : c'est l'objet du Bloc 3. La cybersécurité n'a de sens que dans un environnement dont la sûreté est déjà assurée.

> **À retenir**
>
> Dans le vocabulaire de ce cours, distinguez la cause (panne, erreur, malveillance) du besoin atteint. Une panne et une attaque peuvent toutes deux rendre un service indisponible ; une erreur d'envoi peut porter atteinte à la confidentialité.

Les quatre principes DICP

Situation	Principe menacé	Ce qu'il garantit
L'ENT tombe en panne	**Disponibilité**	Un service accessible quand on en a besoin
Une note trafiquée dans la base	**Intégrité**	Des données correctes, non altérées
Un dossier médical consulté par un tiers	**Confidentialité**	Un accès réservé aux personnes autorisées
Qui a fait quoi, quand ?	**Preuve**	La capacité d'établir et de démontrer une action

Principe	Question à poser
Disponibilité	Peut-on accéder au service quand on en a besoin ?
Intégrité	Les données ont-elles été altérées sans autorisation ?
Confidentialité	Qui est autorisé à accéder aux données ?
Preuve	Peut-on établir et démontrer ce qui s'est passé ?

Des traces datées et fiables peuvent aider à reconstituer une action. Un compte mentionné dans un journal ne suffit pas à identifier avec certitude la personne qui l'a utilisé. Les mécanismes de preuve seront approfondis dans une séquence ultérieure.

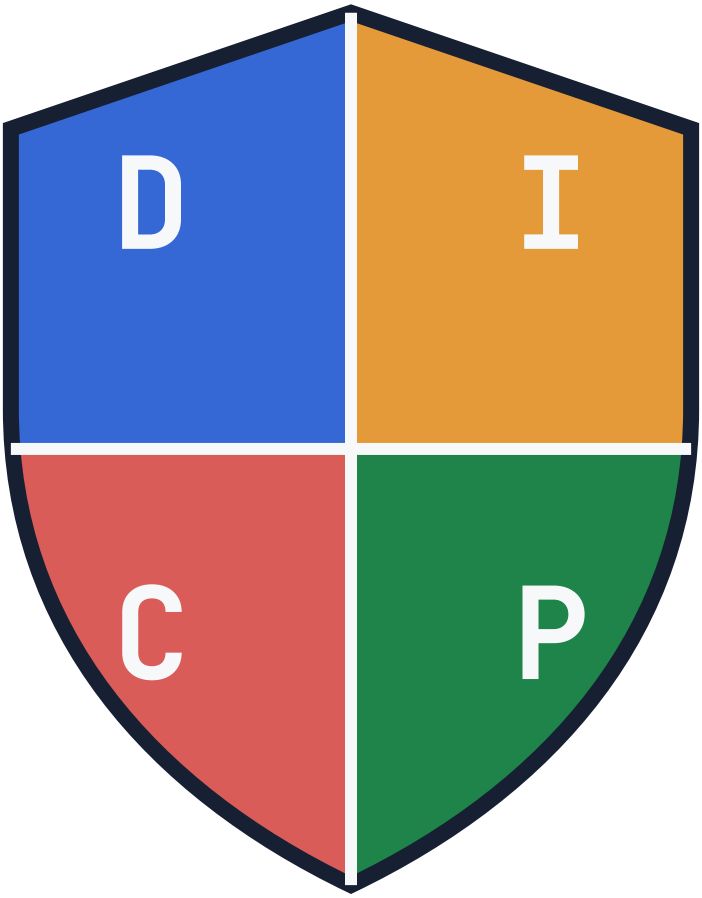


Fig. 1 - Les quatre principes DICP : Disponibilité, Intégrité, Confidentialité, Preuve.

> **À retenir**
>
> DICP n'est pas une liste à réciter : c'est une grille de lecture. Face à tout incident, la première question est « quel principe est menacé ? », avant de chercher une solution technique.

Deux organismes de référence

Repères documentaires pour la suite : leur présentation n'est pas nécessaire au déroulement de l'activité DICP de cette séance.

- **CNIL** (Commission Nationale de l'Informatique et des Libertés) : autorité administrative indépendante française. Informe et protège les citoyens, contrôle les organismes, sanctionne en cas de non-respect du RGPD.
- **ANSSI** (Agence Nationale de la Sécurité des Systèmes d'Information) : dépend du Premier ministre. Défend l'État et les opérateurs vitaux, diffuse des guides et bonnes pratiques, aide en cas d'incident grave.

La suite : deux chemins

À partir du semestre 2, le Bloc 3 se spécialise :

SISR	SLAM
Assurer la cybersécurité d'une infrastructure réseau, d'un système, d'un service	Assurer la cybersécurité d'une solution applicative et de son développement

Partie 3 — Activité : D, I ou C ?

> **Activité**

Demi-groupe · sur feuille · d'abord seul, puis en binôme. **Ordre de travail : exercice 1 → exercice 3 → exercice 2 en restitution. À produire :** les classements, un compte rendu individuel relu en binôme, des réactions justifiées à l'oral et une réponse individuelle de sortie. Le cours est autorisé ; l'IA et la recherche sur Internet ne le sont pas. Aucun logiciel ni manipulation informatique n'est nécessaire. La **Preuve** sera travaillée ultérieurement.

Votre méthode : repérez le service ou les données concernés ; soulignez le fait observé ; choisissez D, I ou C et expliquez le lien. Plusieurs principes peuvent être touchés, mais chaque réponse doit s'appuyer sur un fait du récit. Distinguez **ce qui est constaté** de **ce qui pourrait arriver**.

Exercice 1 — Même effet, causes différentes

Seul, puis comparaison à deux. Pour chaque situation, indiquez le principe principalement touché et recopiez les mots qui justifient votre réponse. Pour A et B seulement, précisez si l'origine relève de la sûreté (panne/aléa) ou de la sécurité (malveillance), selon le vocabulaire du cours.

Cas	Situation
A	Une panne électrique arrête le serveur de réservation du lycée. Personne ne peut réserver une salle.
B	Une personne bloque volontairement ce même serveur. Personne ne peut réserver une salle.
C	Une personne remplace sans autorisation le numéro de compte bancaire sur une facture. Le fichier reste lisible.
D	Un fichier contenant les coordonnées des étudiants est envoyé par erreur à une personne extérieure non autorisée.
E	Une personne sans autorisation consulte les notes d'une classe, sans les modifier.
F	Un programme malveillant modifie les quantités du stock. L'application continue de fonctionner.

Phrase à compléter : « Les cas A et B ont le même effet sur …, mais leur cause diffère car … » Discutez ensuite une réponse sur laquelle vous n'étiez pas d'accord ; chacun corrige sa feuille. Si vous êtes d'accord sur tout, expliquez le cas qui vous a semblé le plus difficile. La correction collective porte sur les désaccords restants. Passez ensuite à l'exercice 3.

Exercice 3 — Un incident, plusieurs conséquences

Seul, puis mise en commun à deux. Le secrétariat utilise un dossier partagé pour organiser les stages. À 9 h, le tableau de suivi ne s'ouvre plus : un message indique que le fichier est chiffré et réclame une rançon. Le responsable constate aussi qu'une copie des conventions, contenant des coordonnées personnelles, est publiée sur une page accessible à tous.

Sur un autre document resté lisible, deux dates de stage ont été modifiées sans autorisation. La cause exacte et l'identité de l'auteur ne sont pas encore établies.

1. Rédigez **trois lignes** : fait constaté → principe touché → conséquence concrète pour les utilisateurs.
2. Rédigez un **signalement de trois phrases** au service informatique : heure et service concernés, faits observés, aide demandée. N'inventez ni cause, ni auteur, ni manipulation déjà effectuée.
3. L'équipe habilitée rétablit ensuite l'accès au tableau depuis une copie saine. Est-ce suffisant pour dire que **toutes** les conséquences sont résolues ? Justifiez avec les deux autres faits.

Relecture croisée. Échangez votre compte rendu avec un voisin. Vérifiez les liens entre faits et principes, l'heure, le service et l'aide demandée. Repérez une cause ou un auteur inventé. Proposez une amélioration précise, puis chacun reprend son texte. Deux comptes rendus seront comparés en restitution, avant la discussion des réactions de l'exercice 2.

Pour aller plus loin : proposez une mesure préventive par principe et expliquez son effet. Une mesure peut réduire un risque sans garantir qu'aucun incident ne surviendra.

Exercice 2 — Choisir une réaction et l'expliquer

En restitution collective, après l'exercice 3 ; à préparer seul si vous terminez plus vite. Pour chaque cas : indiquez le principe menacé ou atteint, choisissez la réaction adaptée et expliquez en une phrase pourquoi l'autre aggraverait la situation. Vous êtes utilisateur du service, sans droit d'administration.

A. Message suspect. Un courriel demande de saisir votre mot de passe sur un site inconnu. Vous n'avez ni cliqué ni saisi d'information.

- **Réaction 1 :** saisir un faux mot de passe pour tester le site.
- **Réaction 2 :** ne pas suivre le lien et signaler le message au service informatique par le canal habituel.

La confidentialité est-elle déjà compromise, ou seulement menacée d'après le récit ?

B. Facture modifiée. Le compte bancaire d'une facture a été remplacé sans autorisation. Le paiement n'est pas encore parti.

- **Réaction 1 :** suspendre le paiement, prévenir le responsable et faire vérifier les coordonnées par un contact déjà connu.
- **Réaction 2 :** payer tout de suite, puis demander une vérification.

C. Dossiers bloqués. Un message de rançon apparaît et les dossiers partagés sont devenus inaccessibles.

- **Réaction 1 :** brancher immédiatement le disque de sauvegarde au poste suspect pour recopier les dossiers.
- **Réaction 2 :** cesser les manipulations et alerter immédiatement le service informatique, en décrivant les faits.

À expliquer : une sauvegarde suffit-elle à annuler la divulgation d'un fichier à une personne non autorisée ?

Avant de partir — Vérification individuelle

Sans le cours, en deux phrases. « Un dossier a été copié par une personne non autorisée. L'original est toujours accessible et n'a pas changé. » Quel principe est atteint ? Pourquoi le fait de pouvoir encore ouvrir l'original ne résout-il pas le problème ?

Corrigés

Découvrir le bloc, nommer les bons principes

BTS SIO 1re année

Introduction à la cybersécurité (DICP)

Classe entière — Construire la grille

Entrée : le service reste accessible (D), mais les notes ont été altérées sans autorisation (I). Une application qui s'ouvre n'est donc pas nécessairement fiable.

Quatre situations : A → disponibilité, B → intégrité, C → confidentialité, D → besoin de preuve. La quatrième situation ne démontre pas qu'une trace a disparu : elle fait apparaître le besoin de disposer d'éléments fiables pour établir les actions. La grille de questions de la partie 2 constitue la synthèse attendue.

Frontières : panne et attaque ont le même effet sur D, mais diffèrent par leur origine. Copier sans autorisation atteint C même si l'original reste intact ; falsifier les stocks atteint I même si l'application fonctionne.

Incident inventé : accepter toute situation cohérente dont le principe est justifié par un fait précis. Demander une reformulation si l'étudiant ne fournit qu'un mot (« piratage », « virus »).

Exercice 1 — Identifier à partir des faits

Cas	Principe principal	Justification
A	D — Disponibilité	Impossible de réserver ; panne électrique : sûreté.
B	D — Disponibilité	Impossible de réserver ; blocage volontaire : sécurité.
C	I — Intégrité	Le numéro de compte a été remplacé sans autorisation.
D	C — Confidentialité	Les coordonnées sont transmises à une personne non autorisée.
E	C — Confidentialité	Des notes sont consultées sans autorisation, même sans modification.
F	I — Intégrité	Les quantités sont modifiées ; le fonctionnement de l'application ne garantit pas leur exactitude.

Les cas A et B empêchent l'accès au même service, mais la panne est accidentelle et le blocage est volontaire. **Le principe décrit le besoin atteint ; il ne suffit pas à identifier la cause.** La confidentialité peut aussi être atteinte par une erreur, comme dans D.

Exercice 3 — Relier chaque principe à une conséquence

Fait constaté	Principe	Conséquence possible pour les utilisateurs
Le tableau ne s'ouvre plus.	D	Le secrétariat ne peut plus consulter le suivi des stages.
Les conventions sont publiées.	C	Des personnes non autorisées peuvent consulter les coordonnées.
Deux dates ont été changées.	I	Le secrétariat risque d'organiser les stages sur des dates erronées.

Exemple de signalement : « À 9 h, le secrétariat ne peut plus ouvrir le tableau partagé de suivi des stages. Un message réclame une rançon, des copies de conventions sont accessibles publiquement et deux dates ont été modifiées sans autorisation dans un autre document. Merci de prendre en charge l'incident et de nous indiquer les consignes à suivre. »

Après restauration : l'accès au tableau est rétabli, mais la publication des conventions et les deux dates modifiées nécessitent encore un traitement. Même retirer la page publique ne permet pas de garantir que personne n'en a conservé une copie. Une origine commune aux trois faits reste une hypothèse, pas une conclusion démontrée.

Extension — réponses possibles : copies de sauvegarde isolées et restauration testée (D) ; limitation des droits de modification et validation des changements sensibles (I) ; limitation des accès et vérification des destinataires/partages (C). Accepter toute mesure pertinente dont le lien avec le risque est expliqué ; ne pas exiger un nom de produit.

Exercice 2 — Réagir sans aggraver

A : C menacée ; réaction 2. Le message cherche à obtenir un secret. Le récit ne permet pas d'affirmer qu'un identifiant a déjà été divulgué. Visiter le site pour le tester constitue une interaction inutile avec un site suspect ; transmettre un faux mot de passe ne prouve pas sa fiabilité.

B : I atteinte ; réaction 1. Le paiement utiliserait une donnée falsifiée. Suspendre et faire vérifier évite d'agir sur cette donnée. Utiliser un contact déjà connu évite de faire confirmer les coordonnées par le canal potentiellement frauduleux. L'utilisateur ne corrige pas arbitrairement le document.

C : D atteinte ; réaction 2. Le service est inaccessible. Brancher la sauvegarde au poste suspect risque de l'exposer à l'incident. L'équipe habilitée organise le confinement, la vérification et la restauration ; restaurer n'est pas une première manipulation à improviser par l'utilisateur. Le récit ne démontre pas une fuite de données : ne pas l'affirmer sans information supplémentaire.

Sauvegarde et divulgation : non. Une copie saine peut aider à retrouver des données disponibles et fiables, mais elle ne retire pas une copie déjà reçue par une personne non autorisée.

Vérification individuelle

La confidentialité est atteinte : une personne non autorisée détient une copie. L'accès à l'original relève de la disponibilité ; son maintien ne retire pas la copie divulguée.